

Configuration environnement Localeo

Configuration environnement Localeo

Objet

Ce document décrit la configuration d'un environnement localeo-backend.

Sources de vérité :

- app/config.py pour les variables métier et techniques lues au démarrage ;
- app/logging_config.py pour les niveaux de logs ;
- app/security/api_keys.py et docs/ops/exploitation.md pour les API keys de batch ;
- les variables injectées par l'hébergeur, par exemple Render.

Règle de sécurité : ne jamais versionner de secrets réels. Les fichiers .env.* partagés doivent rester des gabarits, ou contenir uniquement des valeurs de test non sensibles et remplaçables.

Synthese

Environnement local de développement

Valeurs recommandées :

```
LOCALEO_ENV=local
LOCALEO_APP_ENVIRONMENT=local
EMAIL_DEV_MODE=true
SMS_DEV_MODE=true
LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=true
LOCALEO_DOCUMENT_STORAGE_PROVIDER=LOCAL
```

Usage :

- utiliser .env.local ;
- ne pas utiliser de base de production ;
- ne pas envoyer de vrais emails/SMS sauf test explicite ;
- les defaults de développement sont acceptés.

Tests automatiques locaux

Valeurs recommandées :

```
LOCALEO_ENV=test
LOCALEO_APP_ENVIRONMENT=test-local
EMAIL_DEV_MODE=true
```

SMS_DEV_MODE=true

LOCALEO_DOCUMENT_STORAGE_PROVIDER=LOCAL

LOCALEO_ENV=test est traite comme un environnement de developpement par le code. Il est donc adapte aux tests automatises et aux environnements ephemes, pas a une recette partagee exposee.

Test, recette ou preproduction partagee

Valeurs recommandees :

LOCALEO_ENV=recette

LOCALEO_APP_ENVIRONMENT=test

EMAIL_DEV_MODE=false

SMS_DEV_MODE=false

LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=false

LOCALEO_DOCUMENT_STORAGE_PROVIDER=SCALEWAY_OBJECT_STORAGE

Pourquoi ne pas mettre LOCALEO_ENV=test sur une recette partagee :

- test active les defaults de developpement dans app/config.py ;
- le stockage documentaire repasse en LOCAL si le provider n'est pas force ;
- certains controles de configuration sont moins stricts qu'en environnement non-dev.

Si un environnement Render de test conserve volontairement LOCALEO_ENV=test, il faut renseigner explicitement toutes les variables sensibles et ne pas s'appuyer sur les defaults.

Production

Valeurs recommandees :

LOCALEO_ENV=production

LOCALEO_APP_ENVIRONMENT=production

EMAIL_DEV_MODE=false

SMS_DEV_MODE=false

LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=false

LOCALEO_DOCUMENT_STORAGE_PROVIDER=SCALEWAY_OBJECT_STORAGE

En production :

- tous les secrets doivent venir du gestionnaire de secrets de la plateforme ;
- les fichiers .env ne doivent pas contenir de valeurs reelles ;
- les URL front, Stripe, Brevo, stockage documentaire et CORS doivent pointer vers le bon environnement.

Chargement des variables

app/config.py charge les variables dans cet ordre :

- load_dotenv() charge .env si le fichier existe.
- Si LOCALEO_ENV vaut dev, development, local ou test, et que le runtime n'est pas detecte comme Render, .env.local est charge avec override=True.
- Les variables deja injectees par l'hebergeur restent prioritaires sur Render, car .env.local n'y est pas charge.

Important :

- .env.test n'est pas charge automatiquement par le backend ;
- pour utiliser .env.test, il faut injecter ses valeurs dans l'environnement d'execution, les declarer dans Render, ou les copier temporairement dans .env selon le contexte ;
- .env.local ecrase .env en local si LOCALEO_ENV est un environnement de developpement.

Variables de detection Render :

Cle	Role	Defaut	Obligatoire	Notes
---	---	---	---	---
RENDER	Marqueur runtime Render.	absent	non	Evite le chargement automatique de .env.local.
RENDER_SERVICE_ID	Identifiant service Render.	absent	non	Meme usage que RENDER.
RENDER_EXTERNAL_URL	URL publique Render.	absent	non	Meme usage que RENDER.

Runtime et base de données

Cle	Role	Defaut	Obligatoire	Notes
---	---	---	---	---
LOCALEO_ENV	Mode technique de l'application.	development	recommande	Controle les defaults dev et la validation de configuration.
LOCALEO_APP_ENVIRONMENT	Nom lisible affiche/exploitable.	aucun	non	Permet d'afficher test, recette, production sans changer le comportement technique.
LOCALEO_DATABASE_URL	URL SQLAlchemy PostgreSQL principale.	fallback DATABASE_URL, puis base locale	oui hors local	Prioritaire sur DATABASE_URL.
DATABASE_URL	Alias hebergeur, souvent fourni par Render.	base locale	oui si LOCALEO_DATABASE_URL absent	postgres:// et postgresql:// sont normalises en postgresql+psycopg://.
LOCALEO_AUDIT_EXTERNAL_JSONL_PATH	Export JSONL append-only optionnel des audits.	aucun	non	A utiliser seulement si l'exploitation prévoit un support externe sauvegarde.

Defaut local si aucune URL n'est fournie :

postgresql+psycopg://localeo:localeo@localhost:5432/localeo

Notes d'exploitation :

- l'application accepte postgresql+psycopg://... ;
- les scripts psql, comme scripts/update_existing_database.ps1, doivent recevoir une URL compatible psql, par exemple postgresql://user:password@host:5432/dbname ;
- ne pas utiliser la base locale par defaut sur un environnement partage.

QR coffret

| Cle | Role | Defaut | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_QR_COFFRET_KEY_ID | Identifiant de la cle active de signature QR coffret. | coffret-v1 en dev, sinon aucun | oui | Doit exister dans le keyring. |

| LOCALEO_QR_COFFRET_SECRET | Secret unique de signature QR coffret. | dev-only-qr-coffret-secret en dev, sinon aucun | oui si keyring absent | Mode simple, remplaçable par keyring. |

| LOCALEO_QR_COFFRET_KEYRING | Objet JSON key_id -> secret pour rotation. | construit depuis key id + secret si presents | oui si secret unique absent | Format JSON strict. |

Exemple :

LOCALEO_QR_COFFRET_KEY_ID=coffret-v1

LOCALEO_QR_COFFRET_KEYRING={"coffret-v1":"secret-long","coffret-v0":"ancien-secret"}

Le démarrage échoue si LOCALEO_QR_COFFRET_KEY_ID n'est pas présent dans LOCALEO_QR_COFFRET_KEYRING.

Paieement Stripe

| Cle | Role | Defaut | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_FEATURE_STRIPE_CONNECT_ENABLED | Activation du flux Stripe Connect EPIC 39. | false cible production tant que le go/no-go n'est pas valide | oui pour EPIC 39 | Ne pas activer en production sans validation juridique et finance. |

| LOCALEO_STRIPE_CONNECT_PRODUCTION_GO_NO_GO_VALIDATED | Validation explicite de mise en production Stripe Connect. | false | oui si Connect actif hors dev/test | Doit rester false tant que le dossier juridique/finance n'est pas valide. |

| LOCALEO_STRIPE_SECRET_KEY | Cle serveur Stripe utilisée pour Checkout, Connect, transferts, refunds et lectures Stripe serveur. | aucun | oui | Nom canonique. Les anciens noms STRIPE_API_KEY / STRIPE_SECRET_KEY ne doivent plus être ajoutés aux nouveaux environnements. |

| LOCALEO_STRIPE_WEBHOOK_SECRET | Secret du webhook du compte plateforme Stripe. | aucun | oui | Vérifie Stripe-Signature sur POST /public/stripe/webhook pour les événements de paiement, charge, remboursement et transfert. |

| LOCALEO_STRIPE_CONNECT_WEBHOOK_SECRET | Secret du webhook des comptes connectés. | aucun | oui pour EPIC 39/43 | Vérifie Stripe-Signature sur POST /public/stripe-connect/webhook pour account.updated, account.external_account.updated et les événements payout.*. |

| LOCALEO_STRIPE_API_VERSION | Version Stripe API v1 épinglée. | 2024-06-20 en dev/test | oui si Connect actif | Doit être identique à la version de la destination d'événements Connect. |

| LOCALEO_STRIPE_PAYOUT_ALERT_EMAILS | Destinataires finance/support des alertes critiques de virement. | liste vide | recommande | Liste séparée par des virgules. |

| LOCALEO_STRIPE_ONBOARDING_RETURN_URL | Route de retour onboarding Stripe dans l'application commerçant. | aucun | oui pour EPIC 39 | Exemple : <https://commerçants.localeo.fr/stripe-connect/onboarding/return>. |

| LOCALEO_STRIPE_ONBOARDING_REFRESH_URL | Route de regeneration onboarding Stripe dans l'application commercant. | aucun | oui pour EPIC 39 | Exemple :
https://commercants.localeo.fr/stripe-connect/onboarding/refresh. |
| LOCALEO_FRONT_SUCCESS_URL | URL front après paiement reussi. | https://localeo.app/success | recommande | Peut contenir {CHECKOUT_SESSION_ID}. |
| LOCALEO_FRONT_CANCEL_URL | URL front après annulation. | https://localeo.app/cancel | recommande | Meme usage que success URL. |

Regles :

- ne jamais melanger cles Stripe test et live ;
- separer les webhooks Stripe par environnement ;
- utiliser des destinations d'evenements Stripe API v1 au format Snapshot ;

les evenements v2 Thin ne sont pas pris en charge par ces handlers ;

- configurer la destination du compte plateforme vers POST /public/stripe/webhook avec checkout.session.completed, checkout.session.expired, checkout.session.async_payment_failed, payment_intent.succeeded, payment_intent.payment_failed, charge.succeeded, charge.failed, charge.refunded, refund.created, refund.updated, refund.succeeded, refund.failed, transfer.created, transfer.updated et transfer.reversed ;

- configurer la destination des comptes connectes vers

POST /public/stripe-connect/webhook avec uniquement account.updated ;

- mettre a jour LOCALEO_STRIPE_WEBHOOK_SECRET si la destination plateforme est recreee ;
- mettre a jour LOCALEO_STRIPE_CONNECT_WEBHOOK_SECRET si la destination Connect est recreee ;
- pour Stripe Connect, les URLs d'onboarding doivent pointer vers

l'application commercant ; le backend génère les liens Stripe et l'application commercant affiche le retour ou demande une regeneration.

Exemple production EPIC 39 :

LOCALEO_FEATURE_STRIPE_CONNECT_ENABLED=false

LOCALEO_STRIPE_SECRET_KEY=...

LOCALEO_STRIPE_WEBHOOK_SECRET=...

LOCALEO_STRIPE_CONNECT_WEBHOOK_SECRET=...

LOCALEO_STRIPE_API_VERSION=2024-06-20

LOCALEO_STRIPE_PAYOUT_ALERT_EMAILS=finance@localeo.city,support@localeo.city

LOCALEO_STRIPE_ONBOARDING_RETURN_URL=https://commercants.localeo.fr/stripe-connect/onboarding/return

LOCALEO_STRIPE_ONBOARDING_REFRESH_URL=https://commercants.localeo.fr/stripe-connect/onboarding/refre

URLs front achat, activation et consultation

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---|---

| LOCALEO_FRONT_COMMANDE_URL_TEMPLATE | Lien de gestion d'achat professionnel. |
https://localeo.app/achats/{achat_id}?management_token={management_token} | recommande
 | Doit contenir {achat_id} et {management_token}. |

| LOCALEO_FRONT_ACTIVATION_URL_TEMPLATE | Lien d'activation beneficiaire. |
https://localeo.app/activation?achat_id={achat_id}&coffret_instance_id={coffret_instance_id}&token={token}
 | recommande | Doit contenir les placeholders attendus. |

| LOCALEO_FRONT_CONSULTER_COFFRET_INSTANCE_URL | Lien de consultation sécurisée d'une instance. |
https://localeo.app/coffrets-instances/{coffret_instance_id}?consultation_token={consultation_token}
 | recommande | Contient un token : éviter logs et analytics. |

| LOCALEO_FRONT_CONSULTER_COFFRET_INSTANCE_QR_URL | Variante QR de consultation. | valeur de LOCALEO_FRONT_CONSULTER_COFFRET_INSTANCE_URL | non | Utilisée pour QR/SMS selon parcours. |

| LOCALEO_FRONT_SHORT_LINK_URL_TEMPLATE | Template des liens courts. |
<https://localeo.app/p/{token}> | recommande | Doit contenir {token}. |

| LOCALEO_FRONT_PRINT_QRCODE_URL | Lien d'impression QR. |
{LOCALEO_IMAGE_API_BASE_URL}/coffrets/impression?token={token} | recommande si impression active | Doit contenir {token}. |

| LOCALEO_FRONT_COFFRET_PRINT_URL_TEMPLATE | Alias/template alternatif d'impression coffret. |
 | meme default que LOCALEO_FRONT_PRINT_QRCODE_URL | non | A renseigner explicitement si un consommateur l'utilise. |

| LOCALEO_FRONT_FEEDBACK_PRESTATION_URL_TEMPLATE | Lien feedback post-prestation. |
<https://localeo.app/feedback-prestation?token={token}¬e={note}> | recommande si feedback actif | Doit contenir {token} ; {note} est supporte. |

| LOCALEO_FRONT_COMMERCANT_PASSWORD_INIT_URL_TEMPLATE | Lien initialisation mot de passe marchand. |
<https://localeo.app/commerçants/initialiser-mot-de-passe?token={token}> | recommande | Doit contenir {token}. |

| LOCALEO_FRONT_COMMERCANT_PASSWORD_RESET_URL_TEMPLATE | Lien reset mot de passe marchand. |
<https://localeo.app/commerçants/reinitialiser-mot-de-passe?token={token}> | recommande | Doit contenir {token}. |

Point securite : les URLs contenant des tokens ne doivent pas etre journalisees en clair dans les logs applicatifs, outils analytics ou referrers.

Medias, assets email et DAM

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_IMAGE_API_BASE_URL | Base URL pour liens image/QR. | <http://localhost:8000> |
 recommande hors local | Doit pointer vers une URL publique correcte. |

| LOCALEO_EMAIL_ASSET_BASE_URL | Base URL des assets inclus dans les emails. | valeur de LOCALEO_IMAGE_API_BASE_URL | non | Utile si les assets email sont servis par un autre domaine. |

| LOCALEO_IMAGE_MAX_SIZE_BYTES | Taille max upload image. | 153600 | recommande | 150 KiB par default. |

Gestion documentaire

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_DOCUMENT_STORAGE_PROVIDER | Provider de stockage documentaire. | LOCAL en dev, SCALEWAY_OBJECT_STORAGE hors dev | oui hors local | Valeurs : LOCAL, SCALEWAY_OBJECT_STORAGE, S3. |

| LOCALEO_DOCUMENT_STORAGE_LOCAL_DIR | Repertoire local documentaire. | storage/documents | non | Reserve au local/dev. |

| LOCALEO_DOCUMENT_STORAGE_S3_ENDPOINT_URL | Endpoint S3 compatible. | aucun | oui si provider S3/Scaleway | Exemple Scaleway : https://s3.fr-par.scw.cloud. |

| LOCALEO_DOCUMENT_STORAGE_S3_REGION | Region S3. | fr-par | oui si provider S3/Scaleway | A aligner avec le bucket. |

| LOCALEO_DOCUMENT_STORAGE_S3_BUCKET | Bucket documentaire. | localeo-archives | oui si provider S3/Scaleway | Le bucket doit rester prive. |

| LOCALEO_DOCUMENT_STORAGE_S3_PREFIX | Prefixe des objets. | /archives | recommande | Permet d'isoler l'environnement dans un bucket. |

| LOCALEO_DOCUMENT_STORAGE_S3_ACCESS_KEY | Access key S3. | aucun | oui si provider S3/Scaleway | Secret critique. |

| LOCALEO_DOCUMENT_STORAGE_S3_SECRET_KEY | Secret key S3. | aucun | oui si provider S3/Scaleway | Secret critique. |

| LOCALEO_DOCUMENT_UPLOAD_MAX_SIZE_BYTES | Taille max upload document. | 2097152 | recommande | 2 Mo par default. |

| LOCALEO_DOCUMENT_ALLOWED_MIME_TYPES | MIME types documentaires autorises. | application/pdf,text/html | recommande | Liste CSV. |

Regles :

- les binaires documentaires ne sont pas stockes en base ;
- les documents publics et privs sont servis par le backend ;
- les URLs directes du bucket ne doivent pas etre exposees aux utilisateurs ;
- sur recette/preproduction, forcer explicitement le provider pour eviter un retour involontaire a LOCAL.

Timings, TTL et retention

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_MANAGEMENT_TOKEN_TTL_HOURS | TTL management token achat pro. | 720 | recommande | 30 jours. |

| LOCALEO_COFFRET_INSTANCE_CONSULTATION_TOKEN_EXTENSION_DAYS | Extension consultation après expiration instance. | 30 | recommande | A aligner avec RGPD/metier. |

| LOCALEO_ACTIVATION_EMAIL_RESEND_COOLDOWN_SECONDS | Delai entre deux renvois activation. | 60 | non | Anti-abus fonctionnel. |

| LOCALEO_TRANSACTION_DURATION_SECONDS | Duree transaction validation terrain. | 60 | recommande | Fenetre courte pour limiter la fraude. |

| LOCALEO_VALIDATION_PRESTATION_API_ANNULATION_MAX_HOURS | Fenetre d'annulation directe via API commercant. | 24 | recommande | Au-dela, passer par support/back-office. |

| LOCALEO_COMMERCANT_SESSION_TTL_SECONDS | TTL session commercant. | 1800 | recommande | 30 minutes. |

| LOCALEO_COMMERCANT_SESSION_PURGE_RETENTION_DAYS | Retention sessions expirees/revoquees avant purge. | 30 | recommande RGPD | Utilisee par le batch de purge. |

| LOCALEO_ACTIVITE_LOCALE_PURGE_RETENTION_DAYS | Retention activites locales. | 365 | recommande RGPD | A aligner avec la politique de conservation. |

| LOCALEO_FEEDBACK_PRESTATION_TOKEN_TTL_DAYS | TTL token feedback prestation. | 30 | recommande | Limite la soumission tardive. |

| LOCALEO_COFFRET_INSTANCE_ACTIVATION_TOKEN_TTL_HOURS | TTL token activation beneficiaire. | 168 | recommande | 7 jours. |

| LOCALEO_COFFRET_EXPIRATION_REMINDER_DAYS | Delai avant expiration pour relance. | fallback ancien alias, puis 7 | recommande | Cle cible a utiliser. |

| COFFRET_EXPIRATION_REMINDER_DAYS | Ancien alias du delai de relance. | 7 | non | Compatibilite. |

| LOCALEO_COFFRET_EXPIRATION_REMINDER_WINDOW_HOURS | Fenetre de selection des instances a relancer. | fallback ancien alias, puis 48 | recommande | Cle cible a utiliser. |

| COFFRET_EXPIRATION_REMINDER_WINDOW_HOURS | Ancien alias de fenetre de relance. | 48 | non | Compatibilite. |

WebPush et Localeo Live

Le backend distingue deux canaux WebPush :

- COMMERCANT : notifications live tracking envoyees a l'application commercant.
- LIVE : notifications internes de la PWA Localeo Live / exploitation.

Les anciennes cles generiques LOCALEO_WEBPUSH_* et LOCALEO_FEATURE_LIVE_TRACKING_WEBPUSH_ENABLED restent lues en fallback de compatibilite, mais les nouvelles cles par canal sont la cible de configuration.

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_WEBPUSH_COMMERCANT_ENABLED | Feature flag WebPush commercant. | fallback ancien flag, puis false | oui si fonctionnalite activee | Si false, aucune outbox WebPush commercant n'est creee. |

| LOCALEO_WEBPUSH_COMMERCANT_DEEPLINK_TEMPLATE | Deep link opaque envoye dans le payload commercant. | fallback ancien alias, puis localeo://commercant/live-tracking/{opaque_reference} | recommande | Doit contenir {opaque_reference}. |

| LOCALEO_WEBPUSH_COMMERCANT_DEEPLINK_TTL_HOURS | TTL reference opaque WebPush commercant. | fallback ancien alias, puis 168 | recommande | 7 jours. |

| LOCALEO_WEBPUSH_COMMERCANT_VAPID_PRIVATE_KEY | Cle private VAPID commercant. | fallback ancien alias | oui si canal commercant actif hors local | Secret critique. |

| LOCALEO_WEBPUSH_COMMERCANT_VAPID_PUBLIC_KEY | Cle publique VAPID marchand. | fallback ancien alias | oui si abonnement navigateur actif | Doit correspondre a la cle privee marchand. |

| LOCALEO_WEBPUSH_COMMERCANT_VAPID_SUBJECT | Sujet VAPID marchand. | fallback ancien alias, puis mailto:support@localeo.local | recommande | Email ou URL identifiant l'emetteur. |

| LOCALEO_WEBPUSH_COMMERCANT_ABONNEMENT_REVOQUE_RETENTION_DAYS | Retention trace abonnement marchand revoke. | fallback ancien alias, puis 90 | recommande RGPD | Les secrets d'envoi sont purges des revocations. |

| LOCALEO_WEBPUSH_COMMERCANT_SORTANT_RETENTION_DAYS | Retention notifications WebPush marchand sortantes. | fallback ancien alias, puis 90 | recommande RGPD | Utilise par la purge WebPush actuelle. |

| LOCALEO_WEBPUSH_LIVE_ENABLED | Feature flag WebPush Localeo Live. | true | recommande | Mettre false pour couper abonnements, creation outbox et batch Live. |

| LOCALEO_WEBPUSH_LIVE_VAPID_PRIVATE_KEY | Cle privee VAPID Localeo Live. | fallback ancien alias | oui si canal Live actif hors local | Secret critique, distincte du canal marchand. |

| LOCALEO_WEBPUSH_LIVE_VAPID_PUBLIC_KEY | Cle publique VAPID Localeo Live. | fallback ancien alias | oui si abonnement navigateur actif | Exposee a la PWA Localeo Live. |

| LOCALEO_WEBPUSH_LIVE_VAPID_SUBJECT | Sujet VAPID Localeo Live. | fallback ancien alias, puis mailto:support@localeo.local | recommande | Peut reprendre le meme sujet que le canal marchand. |

| LOCALEO_WEBPUSH_LIVE_ABONNEMENT_REVOQUE_RETENTION_DAYS | Retention trace abonnement Live revoke. | fallback ancien alias, puis 90 | recommande RGPD | Cle preparee pour une purge Live dediee. |

| LOCALEO_WEBPUSH_LIVE_SORTANT_RETENTION_DAYS | Retention notifications WebPush Live sortantes. | fallback ancien alias, puis 90 | recommande RGPD | Cle preparee pour une purge Live dediee. |

| LOCALEO_FEATURE_LIVE_TRACKING_WEBPUSH_ENABLED et LOCALEO_WEBPUSH_* | Anciens alias generiques. | variable | non | Compatibilite uniquement ; ne plus utiliser pour les nouveaux environnements. |

Authentication marchand

| Cle | Role | Defaut | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_BCRYPT_ROUNDS | Cout bcrypt. | 12 | recommande | Tester le temps de login. |

| LOCALEO_PASSWORD_MIN_LENGTH | Longueur minimale mot de passe. | 12 | recommande | Garder 12 hors contrainte produit explicite. |

| LOCALEO_PASSWORD_RESET_TOKEN_TTL_MINUTES | TTL token reset. | 60 | recommande | 1 heure. |

| LOCALEO_PASSWORD_INIT_TOKEN_TTL_HOURS | TTL token initialisation. | 24 | recommande | 24 heures. |

| LOCALEO_AUTH_RATE_LIMIT_WINDOW_SECONDS | Fenetre rate limit auth. | 900 | recommande | 15 minutes. |

| LOCALEO_AUTH_LOGIN_MAX_FAILURES_PER_WINDOW | Echecs login max par fenetre. | 5 | recommande | Anti brute-force. |

| LOCALEO_AUTH_PASSWORD_RESET_MAX_REQUESTS_PER_WINDOW | Demandes reset max par fenetre. | 5 | recommande | Anti spam/reset abuse. |
| LOCALEO_AUTH_ACCOUNT_LOCK_MAX_FAILURES | Echecs consecutifs avant verrouillage. | 5 | recommande | Deblocage via back-office. |

Back-office admin

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_ADMIN_USERNAME | Login SQLAdmin. | admin | oui | Eviter le default sur tout environnement partage. |

| LOCALEO_ADMIN_PASSWORD | Mot de passe SQLAdmin. | change-me | oui | Secret critique. |

| LOCALEO_ADMIN_SESSION_SECRET | Secret de session admin. | dev-only-admin-session-secret en dev, aucun hors dev | oui | Secret critique long et aleatoire. |

| LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS | Autorise config admin faible. | false | non | A reserver au local uniquement. |

La configuration admin faible est refusee sauf si LOCALEO_ENV est dev/local/test et LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=true.

Email, SMS et support

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| BREVO_API_KEY | Cle Brevo generique. | aucun | oui si cles specialisees absentes et dev mode false | Fallback pour email et SMS. |

| BREVO_EMAIL_API_KEY | Cle Brevo email. | fallback BREVO_API_KEY | oui si EMAIL_DEV_MODE=false et pas de fallback | Preferable a la cle generique. |

| BREVO_SMS_API_KEY | Cle Brevo SMS. | fallback BREVO_API_KEY | oui si SMS_DEV_MODE=false et pas de fallback | Preferable a la cle generique. |

| BREVO_SENDER_EMAIL | Expediteur email. | noreply@localeo.city | recommande | Doit etre valide chez Brevo. |

| BREVO_SENDER_NAME | Nom expediteur email. | Localeo | non | Affiche aux destinataires. |

| BREVO_SMS_SENDER | Expediteur SMS. | Localeo | non | Doit respecter les contraintes Brevo/pays. |

| EMAIL_DEV_MODE | Mode email sans envoi reel selon provider. | true en dev, false hors dev | recommande | false sur recette/prod si envoi reel attendu. |

| SMS_DEV_MODE | Mode SMS sans envoi reel selon provider. | true en dev, false hors dev | recommande | false sur recette/prod si envoi reel attendu. |

| LOCALEO_SUPPORT_CONTACT_EMAIL | Destinataire support. | aucun | recommande | Necessaire pour certains messages contact et signalements. |

Facturation Localeo

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_COMPANY_NAME | Nom legal ou commercial de Localeo. | Localeo | recommande | Utilise dans les documents d'achat. |

| LOCALEO_COMPANY_ADDRESS | Adresse de Localeo. | Adresse Localeo a configurer | recommande | Le default ne doit pas rester hors local. |

| LOCALEO_COMPANY_LEGAL_NOTICES | Mentions legales additionnelles. | chaine vide | selon besoin legal | SIRET, TVA, forme sociale, capital, etc. |

Ces valeurs alimentent les documents generes cote achat/facturation. Elles ne correspondent ni a l'adresse du client, ni a l'adresse du commercant.

CORS

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_CORS_ALLOW_ORIGINS | Origines autorisees separees par virgules. | liste vide | recommande si front cross-origin | Si vide et pas de regex, le middleware CORS n'est pas ajoute. |

|

| LOCALEO_CORS_ALLOW_ORIGIN_REGEX | Regex d'origines autorisees. | aucun | non | A eviter sauf besoin clair. |

| LOCALEO_CORS_ALLOW_CREDENTIALS | Autorise credentials CORS. | false | non | Ne pas activer avec wildcard. |

| LOCALEO_CORS_ALLOW_METHODS | Methodes autorisees. | GET,POST,PUT,PATCH,DELETE,OPTIONS | non | Restreindre si possible. |

| LOCALEO_CORS_ALLOW_HEADERS | Headers autorises. |

Authorization,Content-Type,X-API-KEY,X-Management-Token | non | Necessary pour bearer/API keys. |

| LOCALEO_CORS_EXPOSE_HEADERS | Headers exposes au navigateur. | X-Correlation-ID,X-Request-ID | non | X-Correlation-ID est canonique ; X-Request-ID est l'alias deprecie. |

| LOCALEO_CORS_MAX_AGE | Cache preflight CORS. | 600 | non | 10 minutes. |

Logging

Variables lues par app/logging_config.py :

| Cle | Role | Default | Obligatoire | Notes |

|---|---|---:|---:|---|

| LOCALEO_LOG_LEVEL | Niveau global des logs. | INFO | non | Eviter DEBUG hors diagnostic court. |

| LOCALEO_LOG_FORMAT | Formatter de sortie : text ou json. | text en local, json ailleurs | non | Utiliser json sur Render. |

| LOCALEO_LOG_SCHEMA_VERSION | Version du contrat structure. | 1 | non | A incrementer uniquement lors d'une evolution incompatible. |

| LOCALEO_LOG_SERVICE_NAME | Nom du service dans chaque evenement. | localeo-backend | non | Etiquette de recherche Better Stack. |

| LOCALEO_LOG_USER_AGENT_MAX_LENGTH | Taille maximale du User-Agent assaini. | 512 | non | Les caracteres de controle sont supprimes. |

| LOCALEO_LOG_SLOW_USE_CASE_MS | Seuil nominal de lenteur d'un Use Case. | 2000 | non | Emet use_case.slow. |

| LOCALEO_SQL_LOG_LEVEL | Niveau SQLAlchemy. | WARNING | non | Ne pas mettre DEBUG avec données sensibles. |

| LOCALEO_USE_CASES_LOG_LEVEL | Niveau localeo.use_cases. | INFO | non | Diagnostic applicatif. |

| LOCALEO_DOMAINE_LOG_LEVEL | Niveau localeo.domaine.decisions et localeo.domaine.business_rules. | INFO | non | Passer a DEBUG pour les decisions et regles acceptees. |

| LOCALEO_INFRASTRUCTURE_LOG_LEVEL | Niveau localeo.infrastructure. | INFO | non | Logs techniques explicites, sans instrumentation automatique globale. |

| LOCALEO_INVARIANTS_LOG_LEVEL | Niveau localeo.domaine.invariants. | INFO | non | Les invariants invalides restent visibles en WARNING. |

Variables d'exploitation non lues par app/config.py

Certaines variables peuvent apparaitre dans les fichiers .env.* pour les scripts ou l'ordonnancement, sans etre lues directement par app/config.py.

| Cle | Usage | Notes |

---|---|---

| LOCALEO_INTERNAL_BATCH_API_KEY | Valeur brute envoyee dans le header X-API-KEY par les scripts/ordonnanceurs. | Le backend valide cette valeur contre la table api_keys; la variable seule ne suffit pas. |

| LOCALEO_QR_CARTE_KEY_ID | Ancienne ou future convention QR carte. | Non lue par app/config.py actuellement. Ne pas la considerer comme active sans code consommateur. |

| LOCALEO_QR_CARTE_KEYRING | Ancienne ou future convention QR carte. | Non lue par app/config.py actuellement. |

Validation au demarrage

En environnement non-dev, validate_runtime_config() refuse le demarrage si un de ces elements manque :

- LOCALEO_QR_COFFRET_KEY_ID ;
- LOCALEO_QR_COFFRET_SECRET ou LOCALEO_QR_COFFRET_KEYRING ;
- LOCALEO_ADMIN_SESSION_SECRET ;
- LOCALEO_DATABASE_URL ou DATABASE_URL si l'application reste sur la base locale par default ;
- LOCALEO_STRIPE_SECRET_KEY ;
- LOCALEO_STRIPE_WEBHOOK_SECRET ;
- BREVO_EMAIL_API_KEY ou BREVO_API_KEY si EMAIL_DEV_MODE=false ;
- BREVO_SMS_API_KEY ou BREVO_API_KEY si SMS_DEV_MODE=false.

Le demarrage est egalement refuse si :

- LOCALEO_QR_COFFRET_KEY_ID n'existe pas dans LOCALEO_QR_COFFRET_KEYRING ;
- la configuration admin est faible, sauf contournement local explicite.

Checklist par environnement

Local

```
LOCALEO_ENV=local
LOCALEO_APP_ENVIRONMENT=local
LOCALEO_DATABASE_URL=postgresql+psycpg://localeo:localeo@localhost:5432/localeo
LOCALEO_QR_COFFRET_KEY_ID=coffret-v1
LOCALEO_QR_COFFRET_KEYRING={"coffret-v1":"dev-only-qr-coffret-secret"}
LOCALEO_ADMIN_USERNAME=admin
LOCALEO_ADMIN_PASSWORD=change-me
LOCALEO_ADMIN_SESSION_SECRET=dev-only-admin-session-secret
LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=true
EMAIL_DEV_MODE=true
SMS_DEV_MODE=true
LOCALEO_DOCUMENT_STORAGE_PROVIDER=LOCAL
```

Recette / test partage

```
LOCALEO_ENV=recette
LOCALEO_APP_ENVIRONMENT=test
LOCALEO_DATABASE_URL=postgresql+psycpg://...
LOCALEO_QR_COFFRET_KEY_ID=coffret-v1
LOCALEO_QR_COFFRET_KEYRING={"coffret-v1":"secret-long-et-aleatoire"}
LOCALEO_ADMIN_USERNAME=...
LOCALEO_ADMIN_PASSWORD=...
LOCALEO_ADMIN_SESSION_SECRET=...
LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=false
LOCALEO_STRIPE_SECRET_KEY=...
LOCALEO_STRIPE_WEBHOOK_SECRET=...
BREVO_EMAIL_API_KEY=...
BREVO_SMS_API_KEY=...
EMAIL_DEV_MODE=false
SMS_DEV_MODE=false
LOCALEO_CORS_ALLOW_ORIGINS=https://test-marketplace.example,https://test-commercant.example
LOCALEO_DOCUMENT_STORAGE_PROVIDER=SCALEWAY_OBJECT_STORAGE
LOCALEO_DOCUMENT_STORAGE_S3_ENDPOINT_URL=https://s3.fr-par.scw.cloud
LOCALEO_DOCUMENT_STORAGE_S3_REGION=fr-par
LOCALEO_DOCUMENT_STORAGE_S3_BUCKET=...
```

LOCALEO_DOCUMENT_STORAGE_S3_PREFIX=/test
LOCALEO_DOCUMENT_STORAGE_S3_ACCESS_KEY=...
LOCALEO_DOCUMENT_STORAGE_S3_SECRET_KEY=...
LOCALEO_COMPANY_NAME=Localeo
LOCALEO_COMPANY_ADDRESS=...
LOCALEO_COMPANY_LEGAL_NOTICES=...

Production

LOCALEO_ENV=production
LOCALEO_APP_ENVIRONMENT=production
LOCALEO_DATABASE_URL=postgresql+psycopg://...
LOCALEO_QR_COFFRET_KEY_ID=coffret-v1
LOCALEO_QR_COFFRET_KEYRING={"coffret-v1":"secret-long-et-aleatoire"}
LOCALEO_ADMIN_USERNAME=...
LOCALEO_ADMIN_PASSWORD=...
LOCALEO_ADMIN_SESSION_SECRET=...
LOCALEO_ALLOW_INSECURE_ADMIN_DEFAULTS=false
LOCALEO_STRIPE_SECRET_KEY=...
LOCALEO_STRIPE_WEBHOOK_SECRET=...
BREVO_EMAIL_API_KEY=...
BREVO_SMS_API_KEY=...
EMAIL_DEV_MODE=false
SMS_DEV_MODE=false
LOCALEO_CORS_ALLOW_ORIGINS=https://coffrets.example,https://commercants.example
LOCALEO_DOCUMENT_STORAGE_PROVIDER=SCALEWAY_OBJECT_STORAGE
LOCALEO_DOCUMENT_STORAGE_S3_ENDPOINT_URL=https://s3.fr-par.scw.cloud
LOCALEO_DOCUMENT_STORAGE_S3_REGION=fr-par
LOCALEO_DOCUMENT_STORAGE_S3_BUCKET=...
LOCALEO_DOCUMENT_STORAGE_S3_PREFIX=/production
LOCALEO_DOCUMENT_STORAGE_S3_ACCESS_KEY=...
LOCALEO_DOCUMENT_STORAGE_S3_SECRET_KEY=...
LOCALEO_DOCUMENT_UPLOAD_MAX_SIZE_BYTES=2097152
LOCALEO_DOCUMENT_ALLOWED_MIME_TYPES=application/pdf,text/html
LOCALEO_COMPANY_NAME=Localeo
LOCALEO_COMPANY_ADDRESS=...
LOCALEO_COMPANY_LEGAL_NOTICES=...

Controle rapide d'un fichier .env.*

Avant de deployer un environnement partage, verifier au minimum :

- aucune valeur ne pointe vers localhost ;
- LOCALEO_ENV n'est pas local, developement ou test sauf choix explicite ;
- LOCALEO_APP_ENVIRONMENT identifie clairement l'environnement ;
- LOCALEO_DATABASE_URL cible la bonne base ;
- LOCALEO_STRIPE_SECRET_KEY, LOCALEO_STRIPE_WEBHOOK_SECRET et LOCALEO_STRIPE_CONNECT_WEBHOOK_SECRET appartiennent au meme environnement Stripe ;
- EMAIL_DEV_MODE et SMS_DEV_MODE correspondent au comportement attendu ;
- LOCALEO_DOCUMENT_STORAGE_PROVIDER et les variables S3 sont coherents ;
- LOCALEO_CORS_ALLOW_ORIGINS liste uniquement les fronts autorises ;
- LOCALEO_COMPANY_ADDRESS ne garde pas le default Adresse Localeo a configurer ;
- les secrets sont stockes dans le secret manager et non dans Git.